# TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

# TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

## INTRODUCTION:

In today's digital environment, organizations rely heavily on remote access and cloud-based services to perform daily operations. Traditional security models that depend on network-based access, such as Virtual Private Networks (VPNs), often grant users broad access to internal networks. This approach increases the attack surface and allows attackers to move laterally within the network once access is obtained.

To overcome these limitations, modern cybersecurity frameworks adopt the Zero Trust security model, which follows the principle of “never trust, always verify.” Instead of trusting users based on their network location, Zero Trust continuously verifies user identity, device posture, and contextual information before granting access to resources.

This project focuses on implementing Zscaler Private Access (ZPA) to enforce identity-aware and application-specific access policies. ZPA enables secure connectivity between users and applications without exposing the internal network. It creates secure micro-tunnels that allow users to access only the applications they are authorized to use.

By implementing least-privilege access policies, organizations can reduce security risks, prevent unauthorized access, and protect sensitive data. This approach significantly improves the overall cybersecurity posture of the organization while providing secure and seamless access to internal applications.

## ABSTRACT

With the rapid growth of digital transformation and remote work environments, traditional perimeter-based security models are no longer sufficient to protect organizational resources. Conventional VPN-based solutions provide users with extensive network access, which can increase the risk of cyberattacks, unauthorized access, and lateral movement within the network.

This project proposes the implementation of a Zero Trust Architecture using Zscaler Private Access (ZPA) to provide secure, identity-aware access to internal applications. The system ensures that users connect only to the applications they are authorized to access rather than the entire network. Access decisions are made based on multiple contextual factors including user identity, device security posture, location, and access policies.

The project also includes vulnerability assessment using tools such as Nessus Scanner and Burp Suite to identify potential security weaknesses in web applications and networks. By detecting vulnerabilities such as Cross-Site Scripting, SQL Injection, and information exposure, the system provides insights into improving the security posture of the organization.

The implementation of this solution helps enforce the principle of least privilege, reduces the attack surface, and prevents unauthorized access to sensitive resources. Ultimately, this project demonstrates how modern cybersecurity technologies and threat intelligence mechanisms can be used to build a secure and resilient IT infrastructure.

## USE CASE SCENARIO:

### Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with Multi-Factor Authentication (MFA).

ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only.

The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

• User authenticated and authorized based on identity and group membership

• Direct micro-tunnel established specifically to the ERP application

• All other internal applications and network segments remain invisible and inaccessible

## Scenario 2: Contractor Access to Project Git Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group.

When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance such as OS patch level and firewall enabled.

ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM).

The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

• Time-bound and role-specific access enforced

• Contractor restricted to a single application (Git repository)

• Lateral movement to adjacent systems completely blocked

## Scenario 3: Executive Access to Confidential Board Documents

A company executive needs to access a confidential folder containing board meeting materials hosted on an internal file server. The executive connects from a tablet device while traveling internationally.

ZPA integrates with the mobile device management (MDM) solution to verify that the tablet is compliant. The system checks that the device is not jailbroken, has passcode protection enabled, and encryption active.

Upon successful authentication, ZPA evaluates the policy: If the user is in the "Executive_Board" group AND the device is MDM compliant AND the connection is from a trusted country allowlist, then access to the "Board_Documents" application is granted.

The executive is connected directly to the specific file share, and all data in transit is encrypted via TLS. Any attempt to access other shares or network resources is automatically blocked and logged.

Output:
• Context-aware access based on user role, device posture, and geographic location
• Granular access to a specific file share (Board_Documents)
• Comprehensive logging of access events for audit and compliance

**Scenario 4: IT Administrator Access to Server Management Interfaces**

A systems administrator requires access to management interfaces such as SSH for Linux servers and RDP for Windows servers to perform routine maintenance.

Instead of granting VPN access to the entire management network, ZPA is configured to treat each server or management interface as a separate application segment.

The administrator authenticates and is presented only with the specific servers they are authorized to manage based on their IT subgroup. For example, members of "Linux_Admins" can see only Linux servers, while members of "Windows_Admins" can see only Windows servers.

When the administrator connects via SSH to a Linux server, ZPA creates a direct micro-tunnel to that specific IP address and port combination.

The administrator cannot scan the subnet, access other servers, or initiate connections to non-authorized ports.

Output:
• Access limited only to authorized servers
• Direct micro-tunnel established to specific server and port
• Network scanning and unauthorized access completely blocked

# STAGE 1

## TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

## INTRODUCTION:

In today's digital environment, organizations rely heavily on remote access and cloud-based services to perform daily operations. Traditional security models that depend on network-based access, such as Virtual Private Networks (VPNs), often grant users broad access to internal networks. This approach increases the attack surface and allows attackers to move laterally within the network once access is obtained.

To overcome these limitations, modern cybersecurity frameworks adopt the Zero Trust security model, which follows the principle of “never trust, always verify.” Instead of trusting users based on their network location, Zero Trust continuously verifies user identity, device posture, and contextual information before granting access to resources.

This project focuses on implementing Zscaler Private Access (ZPA) to enforce identity-aware and application-specific access policies. ZPA enables secure connectivity between users and applications without exposing the internal network. It creates secure micro-tunnels that allow users to access only the applications they are authorized to use.

By implementing least-privilege access policies, organizations can reduce security risks, prevent unauthorized access, and protect sensitive data. This approach significantly improves the overall cybersecurity posture of the organization while providing secure and seamless access to internal applications.

**COLLEGE NAME:** KPR COLLEGE OF ARTS SCIENCE AND RESEARCH

**DEPARTMENT:** B.Sc. COMPUTER SCIENCE WITH DATA ANALYTICS

**TEAM MEMBERS:**

| SNO | REGISTER NUMBER | NAME | COLLEGE | EMAIL |
|---|---|---|---|---|
| 1 | 2328B0049 | MUPIDATHI DAKSHATHA S (TEAM LEADER) | KPRCAS | 23bda039@kprcas.ac.in |
| 2 | 2328B0013 | AKSHAY PRASAD K | KPRCAS | 23bda003@kprcas.ac.in |
| 3 | 2328B0071 | SRIMATHI K | KPRCAS | 23bda061@kprcas.ac.in |
| 4 | 2328B0055 | PRADEEP LINGAM S | KPRCAS | 23bda045@kprcas.ac.in |
| 5 | 2328B0056 | PRAKSSHETHA G | KPRCAS | 23bda046@kprcas.ac.in |

## VULNERABILITY TABLE:

| S. No. | VULNERBILITY NAME | CWE NO |
|---|---|---|
| 1 | Cross Site Scripting (Stored) | CWE-79 |
| 2 | Broken Access Control | CWE-285 |
| 3 | SQL Injection | CWE- 89 |
| 4 | Broken Authentication | CWE- 285 |
| 5 | Insecure Direct Object Reference | CWE- 639 |
| 6 | Security Misconfiguration | CWE- 732 |
| 7 | Cross Site Request Forgery | CWE- 352 |
| 8 | Cleartext Transmission of Sensitive Information | CWE- 319 |
| 9 | Clickjacking | CWE- 1021 |
| 10 | Password Auto Completion Enabled | CWE- 310 |
| 11 | DOM Based Cross Site Scripting | CWE- 79 |
| 12 | JQuery Multiple XSS | CWE- 79 |
| 13 | Information Exposure (HTTP Header Internal IP Disclosure) | CWE- 200 |
| 14 | Information Exposure (SSL Issues) | CWE- 200 |
| 15 | Information Exposure (HTTP Issues) | CWE- 200 |
| 16 | OS Identification Failed | CWE- 200 |

1. **Vulnerability Name: Cross-Site Scripting (Stored)**

CWE Number: CWE-79

**Description :** Cross-Site Scripting (XSS) is a web security vulnerability where attackers insert malicious scripts into a web application. These scripts are stored in the server and later executed in the browser of other users who visit the affected page.

**Business Impact :** This vulnerability can allow attackers to steal sensitive information such as user credentials, session cookies, or personal data. It can also allow attackers to perform actions on behalf of legitimate users.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter: http://testfire.net/search.jsp?query='>alert('hacked')

**Steps to Reproduce:**

1. Open the website http://testfire.net/.
2. Navigate to the search box in the application.
3. Enter the script '>alert('hacked').
4. Submit the input.
5. A pop-up alert box appears showing “hacked”, confirming the XSS vulnerability.

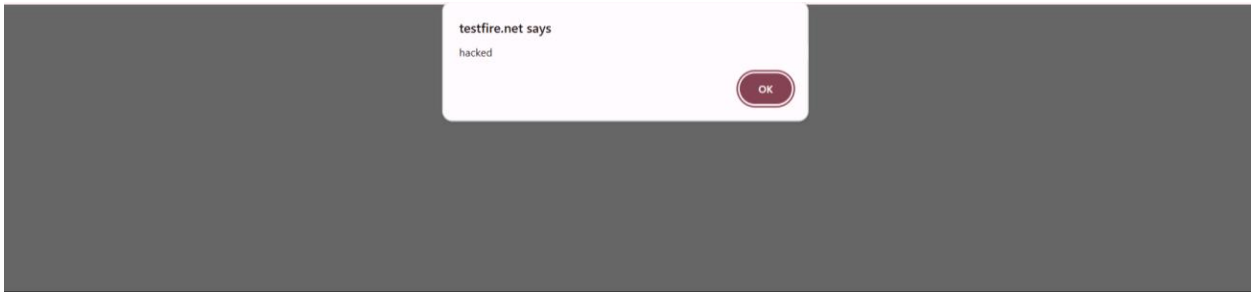
**Recommendation:**

Use output encoding to prevent script execution.

Implement secure coding practices to prevent injection attacks.

Validate and sanitize all user inputs

**Screenshot:**



**2. Vulnerability Name: Broken Access Control**

CWE No: CWE-285

**Description:** Broken Access Control occurs when a system does not properly restrict users from accessing data or functions that they are not authorized to use.

**Business Impact:** Attackers may gain unauthorized access to sensitive data, modify user information, or perform administrative actions.

Vulnerability Path: http://testfire.net/login.jsp

**Steps to Reproduce:**

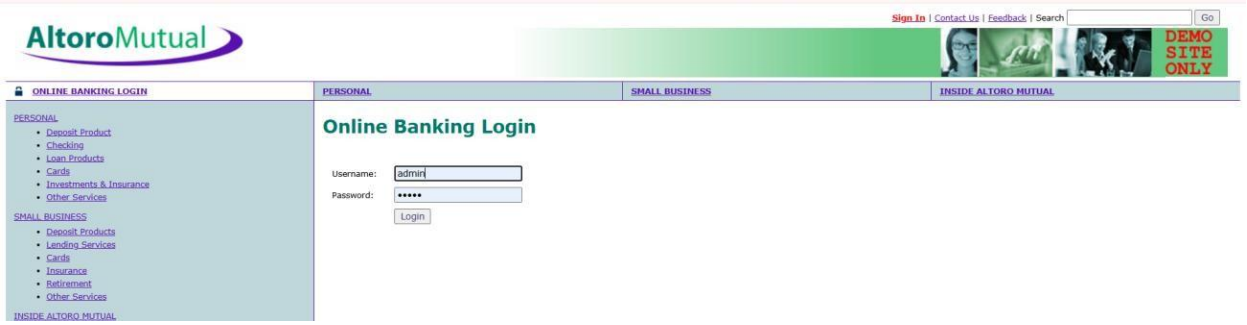
1. Open the website http://testfire.net/.
2. Try logging in using admin credentials.
3. Capture the request using Burp Suite.
4. The request shows username and password in clear text.

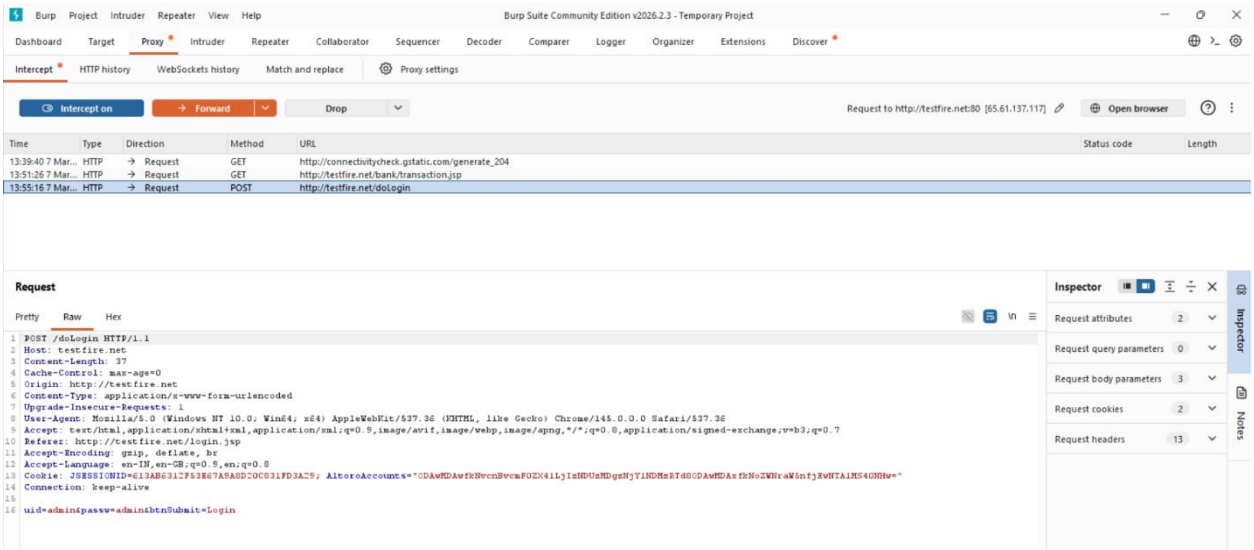
**Recommendation:**

Implement strong authentication and authorization mechanisms.

Use secure session management to protect user access.

**Screenshot:**




## 3. Vulnerability Name: SQL Injection

**CWE No:** CWE-89

**Description:** SQL Injection occurs when an attacker inserts malicious SQL queries into input fields to manipulate the database.

**Business Impact:** Attackers can access sensitive data, modify database records, or gain unauthorized administrative access.

Vulnerability Path: http://testfire.net/login.jsp

**Steps to Reproduce:**

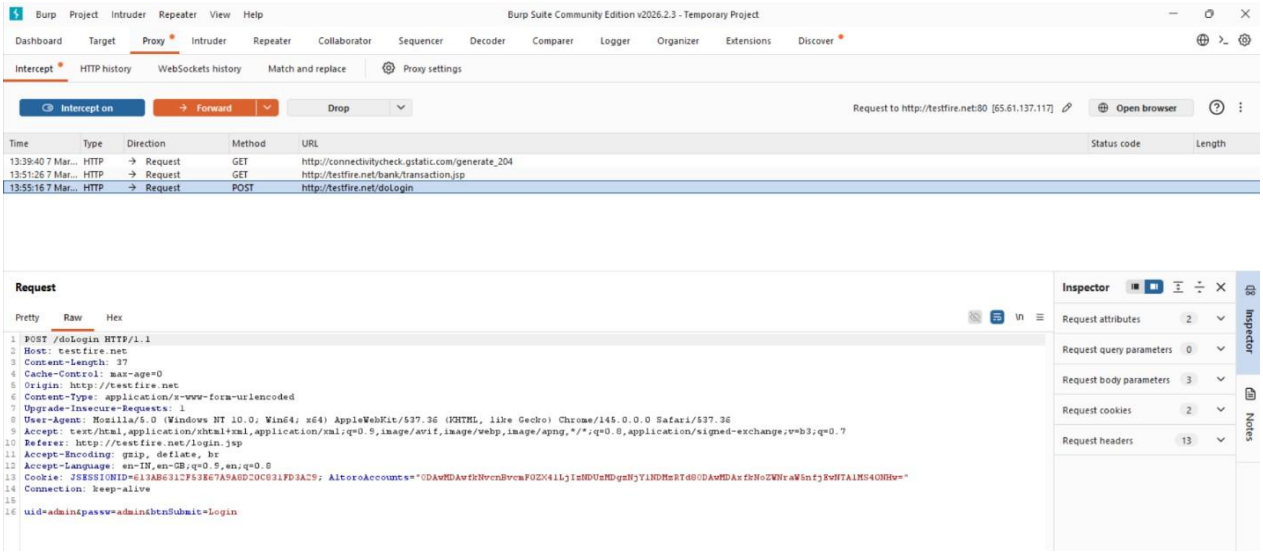
1. Open the website http://testfire.net/.
2. Enter SQL injection payload in the login form.
3. Capture the request using Burp Suite.
4. The attacker may gain admin access without a valid password.

**Recommendation:**

Use parameterized queries or prepared statements.

Validate and sanitize all user inputs.

**Screenshot:**




## 4. Vulnerability Name: Broken Authentication

**CWE No:** CWE-285

**Description:** Broken Authentication occurs when the system fails to properly manage user authentication. Attackers can bypass login mechanisms and access other user accounts.

**Business Impact:** Attackers may gain unauthorized access to user accounts and sensitive information.

**Vulnerability Path: http://testfire.net/login.jsp**

**Steps to Reproduce:**

1. Open the website **http://testfire.net/**.
2. Try logging in with manipulated username inputs.
3. Use SQL injection to bypass password verification.
4. Access to another user account is granted.

**Recommendation:**

Implement strong authentication mechanisms such as Multi-Factor Authentication (MFA).

Use secure password storage and proper session management.

**Screenshot:**

## 5. Vulnerability Name: Insecure Direct Object Reference (IDOR)

**CWE No**: CWE-639

**Description:** IDOR occurs when a web application allows users to access or modify data by changing object identifiers such as user IDs or parameters in the URL.

**Business Impact:** Attackers can access or modify sensitive information of other users without proper authorization.

Vulnerability Path: **http://testfire.net/bank/transfer.jsp**

**Steps to Reproduce:**

1. Open the website **http://testfire.net/**.
2. Login to the application.
3. Go to the "Transfer Money" section.
4. Intercept the request using Burp Suite and modify the transfer amount.

**Recommendation:**

Implement proper access control checks.

Validate user permissions before allowing access to sensitive data.

**Screenshot:**

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

## 6. Vulnerability Name : Security Misconfiguration

**CWE No :** CWE-732

**Description :** Security Misconfiguration occurs when systems are not securely configured, allowing unauthorized access to sensitive files or directories.

**Business Impact :** Attackers may access confidential information, system files, or hidden directories due to weak security settings.

Vulnerability Path : **http://testfire.net/**

**Steps to Reproduce :**

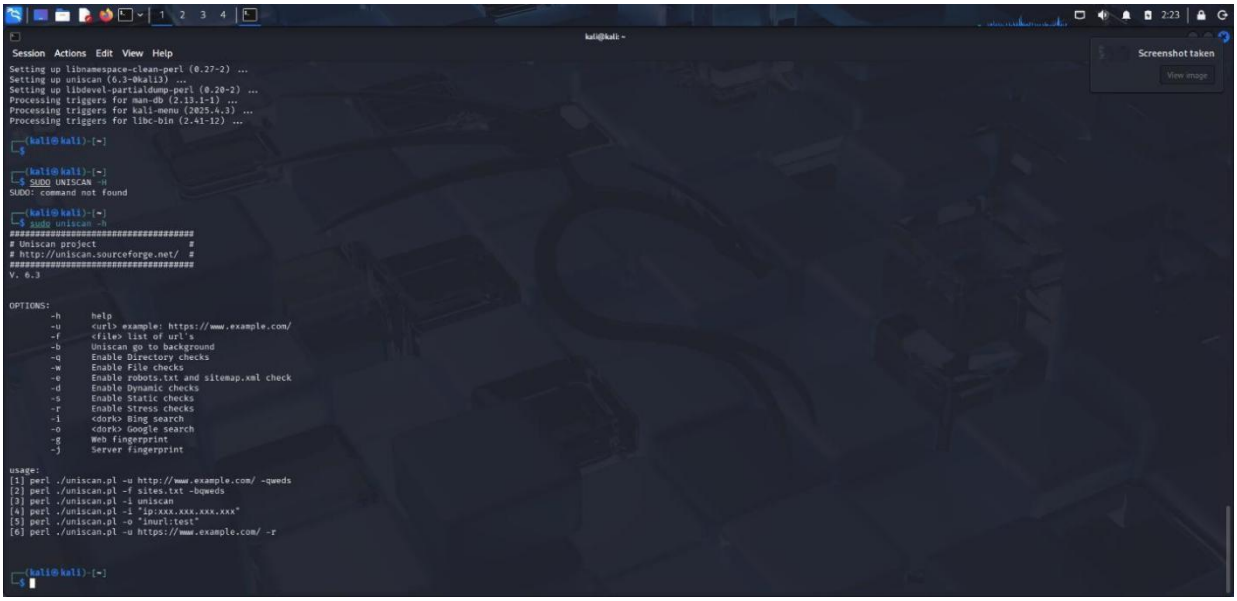
1. Open the website **http://testfire.net/**.
2. Use scanning tools such as Uniscan in Kali Linux.
3. Scan the website for hidden directories.
4. The scan reveals accessible directories and sensitive files.

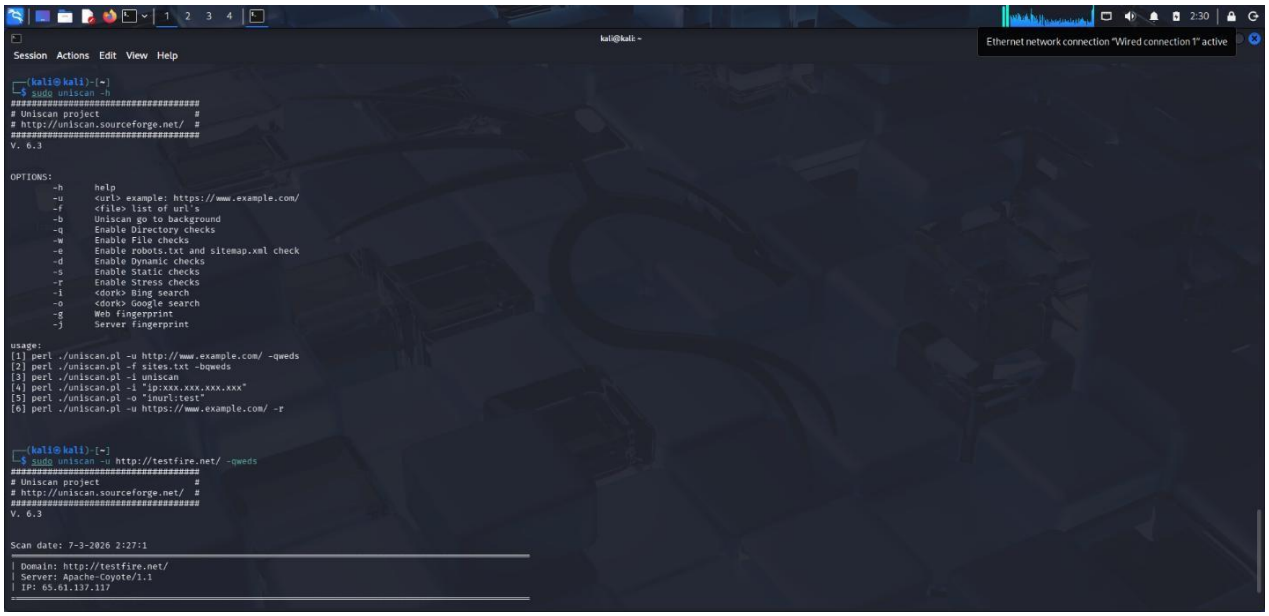
**Recommendation :**

Apply secure configuration settings for servers and applications.

Regularly perform security audits and vulnerability scans.

**Screenshot :**






7. **Vulnerability Name : Cross-Site Request Forgery (CSRF)**

**CWE No :** CWE-352

**Description :** CSRF is an attack that tricks a logged-in user into performing unwanted actions on a web application without their knowledge.

**Business Impact :** Attackers can perform actions such as transferring funds or changing user data using the victim's authenticated session.

Vulnerability Path : **http://testfire.net/bank/transfer.jsp**

**Steps to Reproduce :**

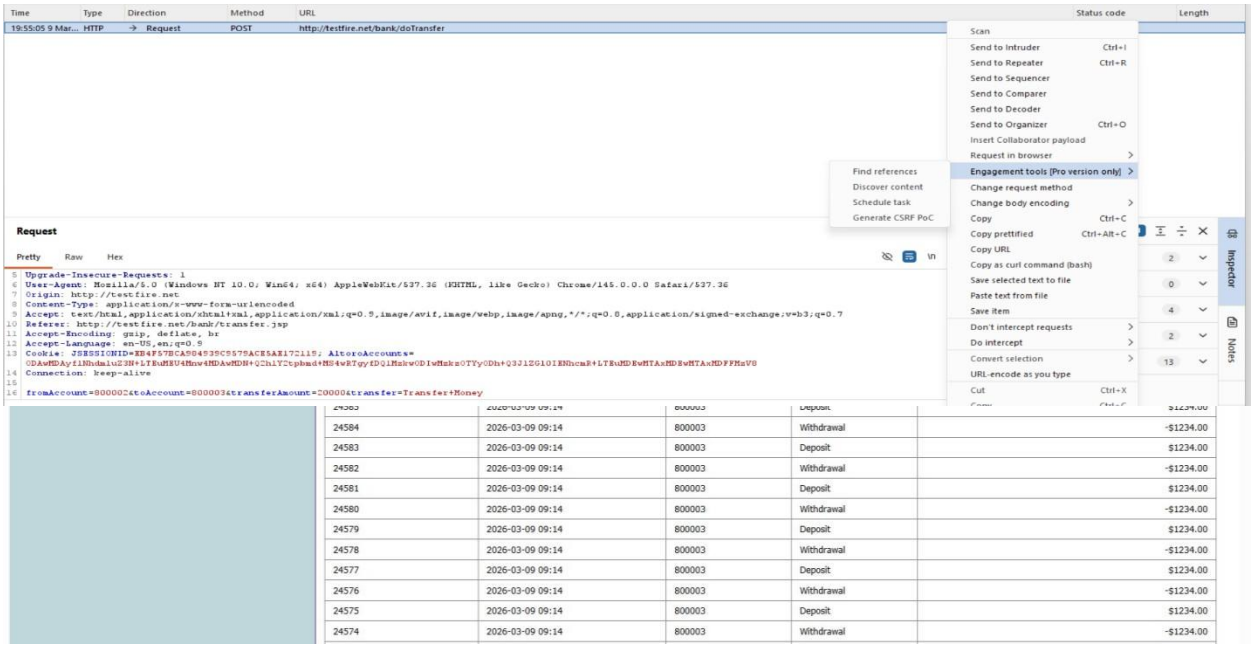
1. Open the website **http://testfire.net/**.
2. Login using valid credentials.
3. Capture the transfer request using Burp Suite.
4. Generate a CSRF proof-of-concept request to perform the action.

**Recommendation :**

Implement CSRF tokens to validate requests.

Use secure session management techniques.

**Screenshot :**




8. **Vulnerability Name : Cleartext Transmission of Sensitive Information**

**CWE No :** CWE-319

**Description :** This vulnerability occurs when sensitive information such as usernames and passwords is transmitted without encryption over the network.

**Business Impact :** Attackers can intercept network traffic and capture sensitive information, leading to data breaches and unauthorized access.

**Vulnerability Path :** [http://testfire.net/login.jsp](http://testfire.net/login.jsp)

**Steps to Reproduce :**

1. Open the website [http://testfire.net/](http://testfire.net/).

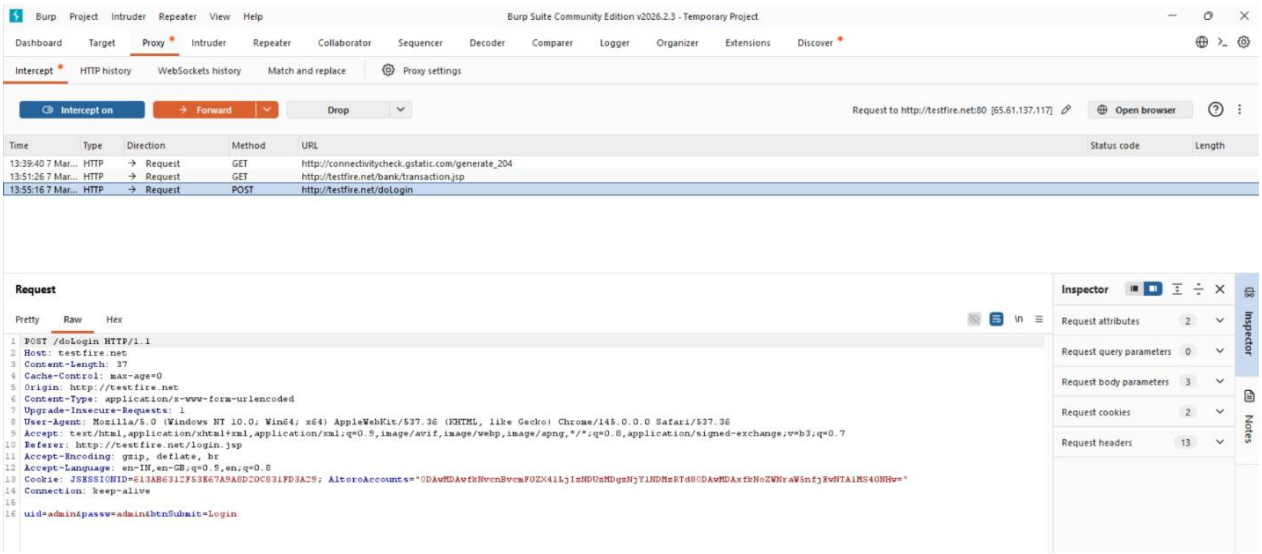
2. Login using admin credentials.
3. Capture the request using Burp Suite.
4. The username and password appear in clear text in the request.

**Recommendation :**

• Use HTTPS with SSL/TLS encryption.

• Ensure sensitive data is always transmitted securely.

**Screenshot :**




9. **Vulnerability Name : Clickjacking**

**CWE No :** CWE-1021

**Description :** Clickjacking occurs when a malicious webpage tricks users into clicking hidden buttons or links by placing the target webpage inside an invisible frame.

**Business Impact :** Attackers can trick users into performing unwanted actions such as clicking buttons, submitting forms, or revealing sensitive information.

Vulnerability Path : **http://testfire.net/**

**Steps to Reproduce :**

1. Open the target website **http://testfire.net/**.
2. Create an HTML page that loads the site inside an iframe.
3. Run the HTML file in a browser.

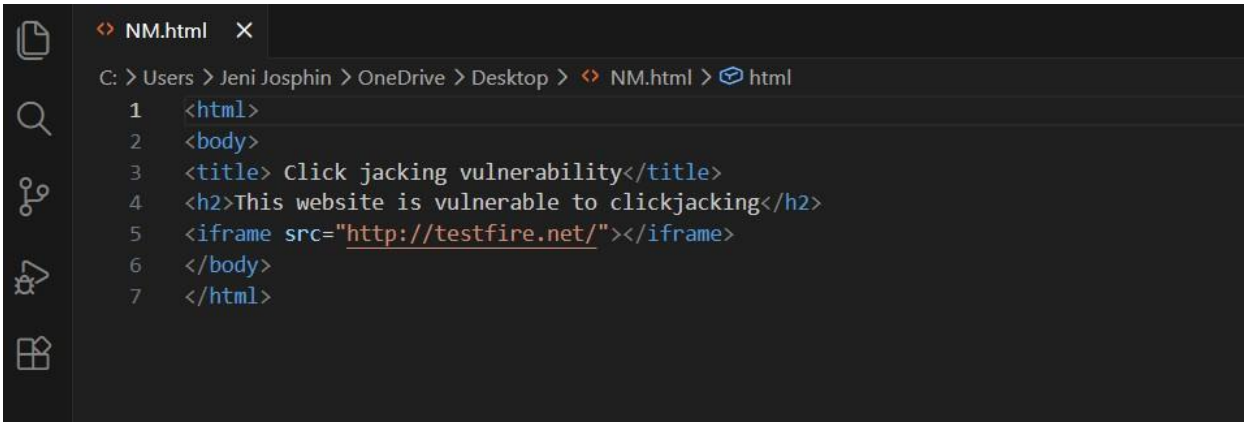
4. The website loads inside the frame, confirming the vulnerability.

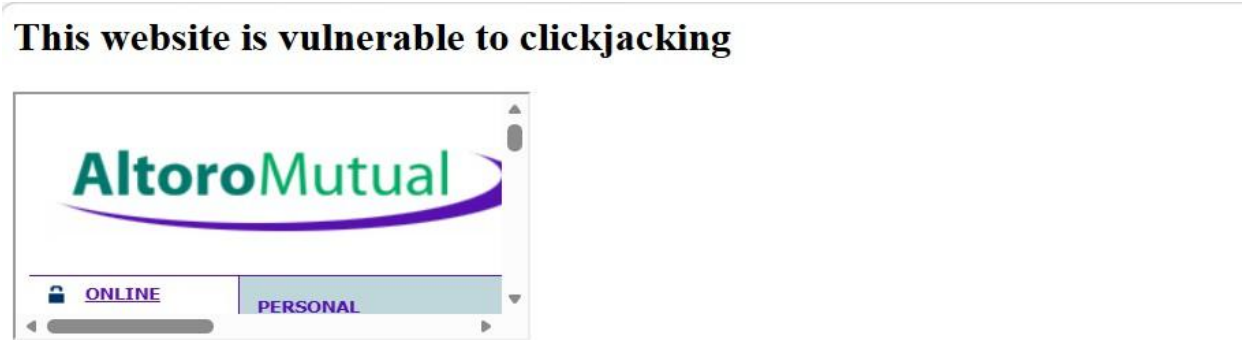
**Recommendation :**

Use X-Frame-Options header to prevent framing.

Implement Content Security Policy (CSP) to block unauthorized embedding.

**Screenshot :**




**10. Vulnerability Name : Web Server Allows Password Auto-Completion**

**CWE No :** CWE-310SSS

**Description :** This vulnerability occurs when the web browser automatically fills previously saved usernames and passwords on login pages.

**Business Impact :** Attackers who gain access to the device can easily view or use stored credentials to access the application.

Vulnerability Path : **http://testfire.net/login.jsp**

**Steps to Reproduce :**

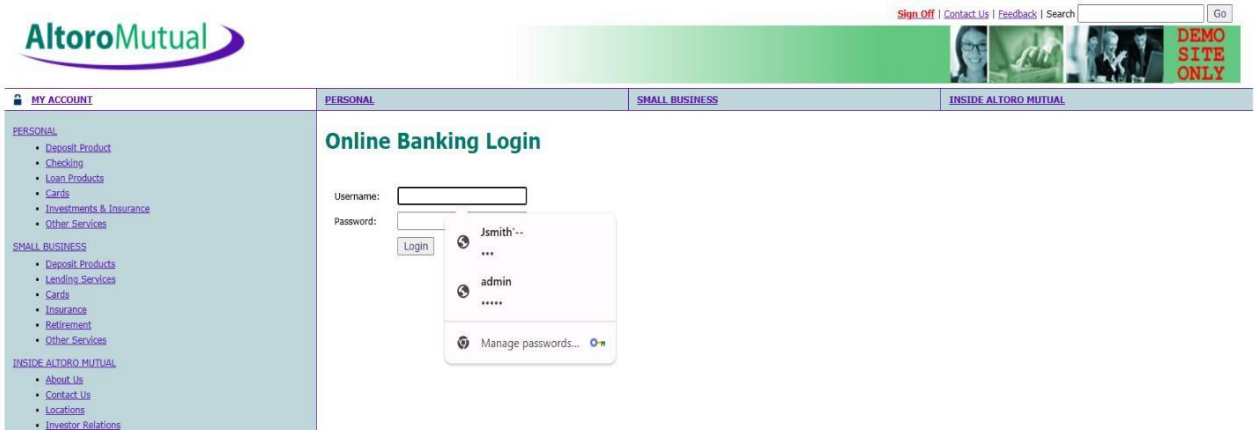
1. Open the website **http://testfire.net/**.
2. Navigate to the login page.
3. Click on the username or password field.
4. The browser automatically suggests stored credentials.

**Recommendation :**

Disable password auto-completion on login forms.

Use secure authentication mechanisms.

**Screenshot :**



**11. Vulnerability Name : Cross-Site Scripting (DOM Based)**

**CWE No** : CWE-79

**Description :** DOM-based XSS occurs when the client-side script processes user input and inserts it into the webpage without proper validation.

**Business Impact :** Attackers can execute malicious scripts in the user's browser and steal sensitive data such as session cookies.

Vulnerability Path : **https://vit.ac.in/**

**Steps to Reproduce :**

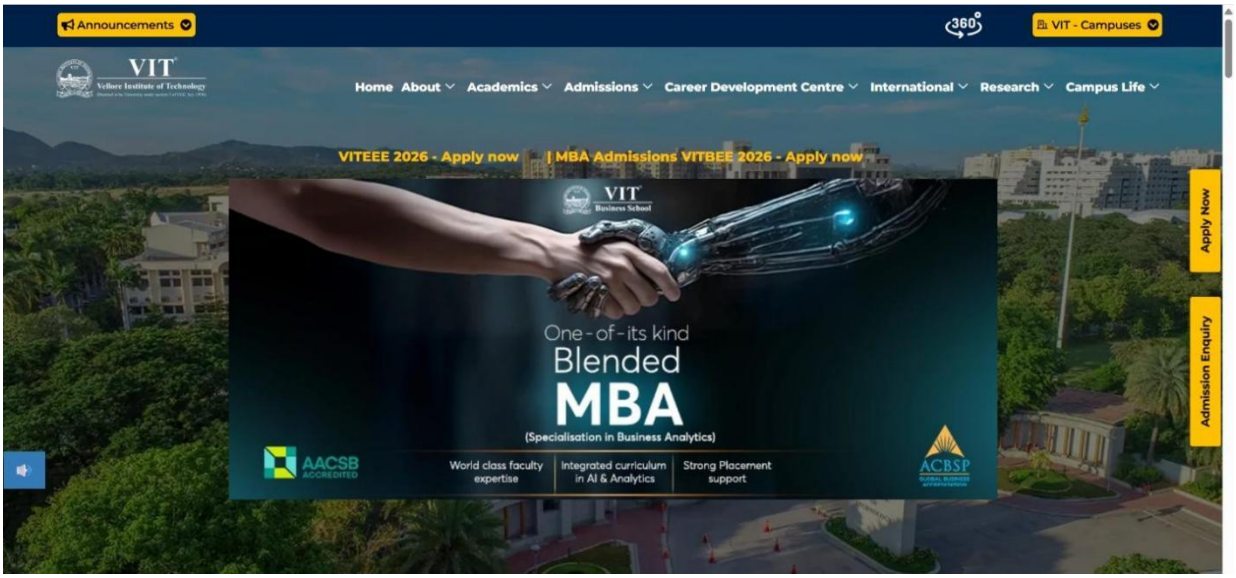
1. Open the website **https://vit.ac.in/**.
2. Inspect the page source using browser developer tools.
3. Identify places where user input is processed by JavaScript.
4. Inject malicious scripts to test for DOM manipulation.

**Recommendation :**

Validate and sanitize user inputs.

Avoid unsafe DOM manipulation methods.

**Screenshot :**



**12. Vulnerability Name : JQuery Multiple XSS**

**CWE No :** CWE-79

**Description :** This vulnerability occurs when outdated versions of JQuery contain security flaws that allow attackers to execute malicious scripts.

**Business Impact :** Attackers can exploit these vulnerabilities to run harmful scripts in the user's browser and steal sensitive data.

Vulnerability Path : **https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js**

**Steps to Reproduce :**

Open the website **https://vit.ac.in/**.

Access the JQuery script used by the website.

Identify the JQuery version in the source code.

Older JQuery versions may contain XSS vulnerabilities.

**Recommendation :**

Update JQuery to the latest secure version.

Regularly update libraries used in web applications.

**Screenshot :**

**13. Vulnerability Name : Information Exposure (Web Server HTTP Header Internal IP Disclosure)**

**CWE No :** CWE-200

**Description :** This vulnerability occurs when the web server reveals internal IP addresses or system information in HTTP response headers.

**Business Impact :** Attackers can use this internal information to identify the system structure and plan further attacks on the network.

Vulnerability Path : https://vit.ac.in/

**Steps to Reproduce :**

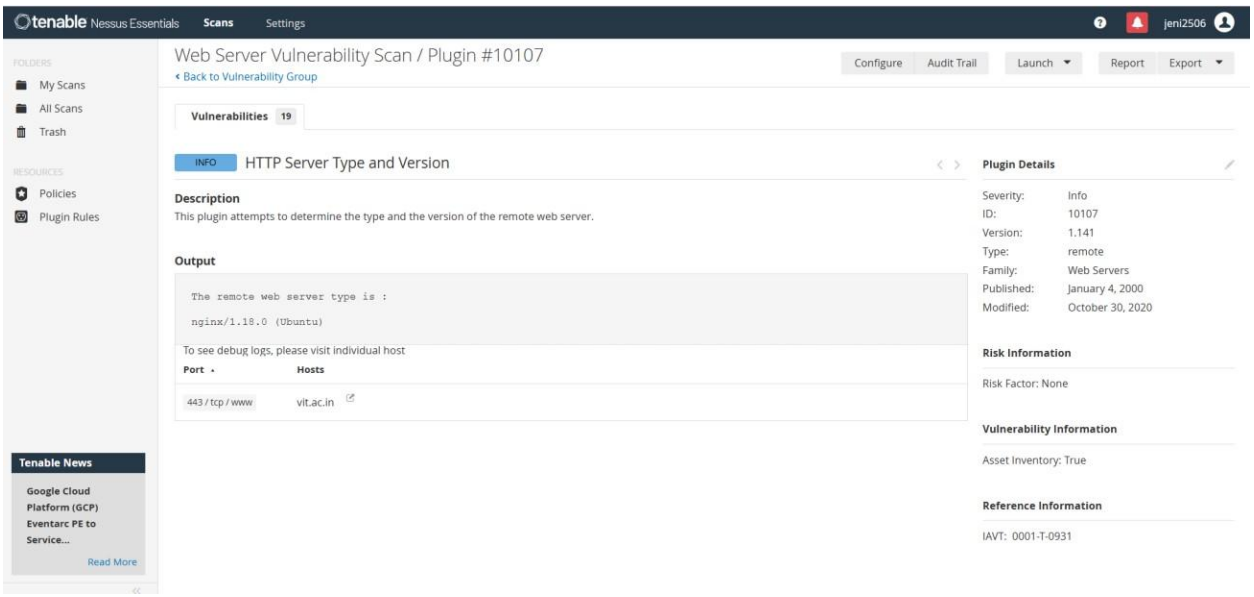
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the HTTP response headers.
4. The scan reveals the internal IP address of the server.

**Recommendation :**

Configure the web server to hide internal IP addresses.

Remove unnecessary information from HTTP response headers.

**Screenshot :**




**14. Vulnerability Name : Information Exposure (SSL Multiple Issues)**

**CWE No :** CWE-200

**Description :** This vulnerability occurs when the SSL/TLS configuration of a website exposes sensitive encryption details or uses weak security protocols.

**Business Impact :** Weak SSL configurations can allow attackers to intercept encrypted communication and access sensitive data.

Vulnerability Path : **https://vit.ac.in/**

**Steps to Reproduce :**

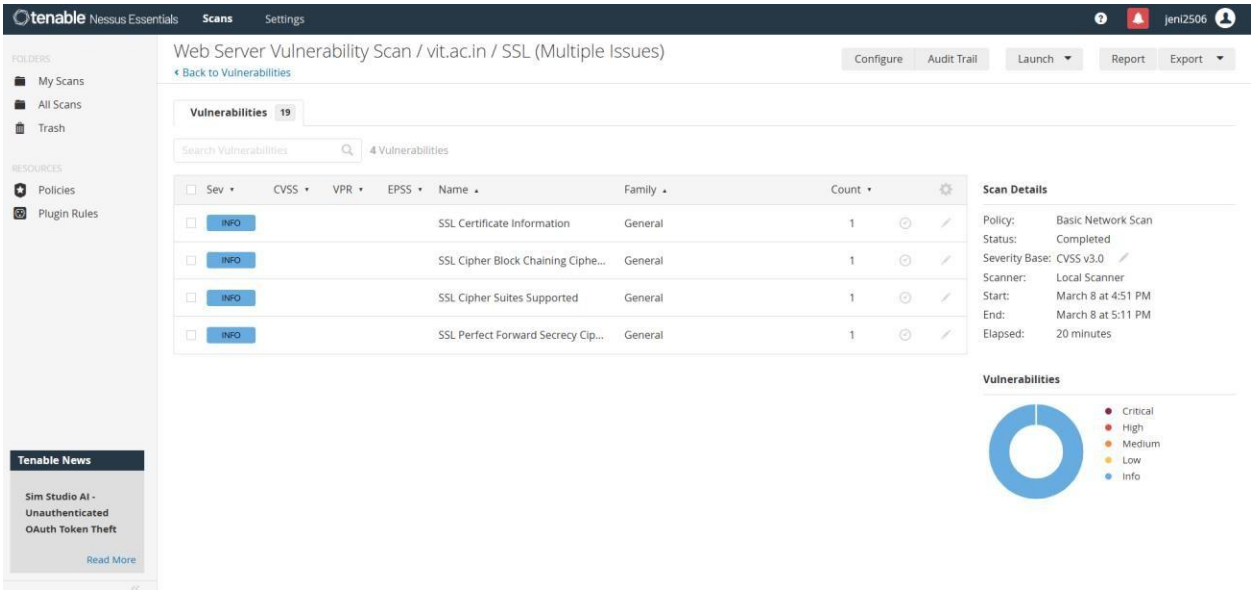
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the SSL/TLS configuration details.
4. The scan shows issues related to encryption protocols.

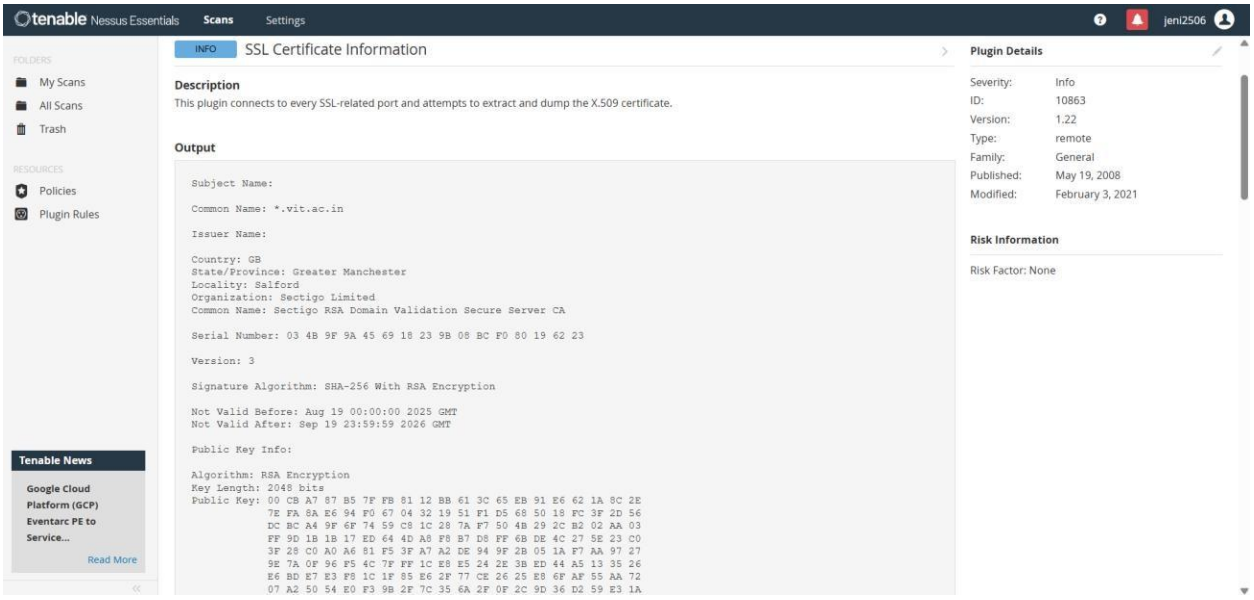
**Recommendation :**

Use strong encryption protocols such as TLS 1.2 or higher.

Disable outdated protocols like SSLv3.

**Screenshot :**




**15. Vulnerability Name : Information Exposure (HTTP Multiple Issues)**

**CWE No :** CWE-200

**Description :** This vulnerability occurs when the web server reveals unnecessary information through HTTP responses such as server details and protocol information.

**Business Impact :** Attackers can gather system information which may help them identify weaknesses and launch further attacks.

Vulnerability Path : **https://vit.ac.in/**

**Steps to Reproduce :**

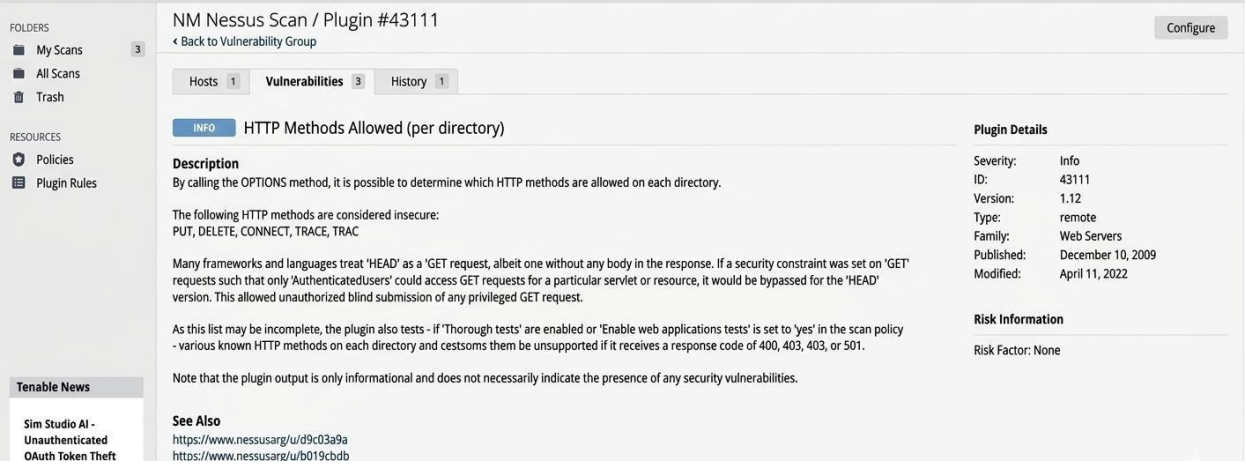
1. Open the target website.
2. Scan the website using Nessus scanner.
3. Review the HTTP response details.
4. The scan reveals server information and protocol details.

**Recommendation :**

Reduce unnecessary information in HTTP responses.

Use secure HTTPS configuration for communication

**Screenshot :**




**16. Vulnerability Name : OS Identification Failed**

**CWE No :** CWE-200

**Description :** OS Identification Failed occurs when a vulnerability scanning tool cannot accurately detect the operating system of the target server.

**Business Impact :** Incorrect system identification may lead to improper security analysis and may hide potential vulnerabilities in the system.

Vulnerability Path : **https://vit.ac.in/**

**Steps to Reproduce :**

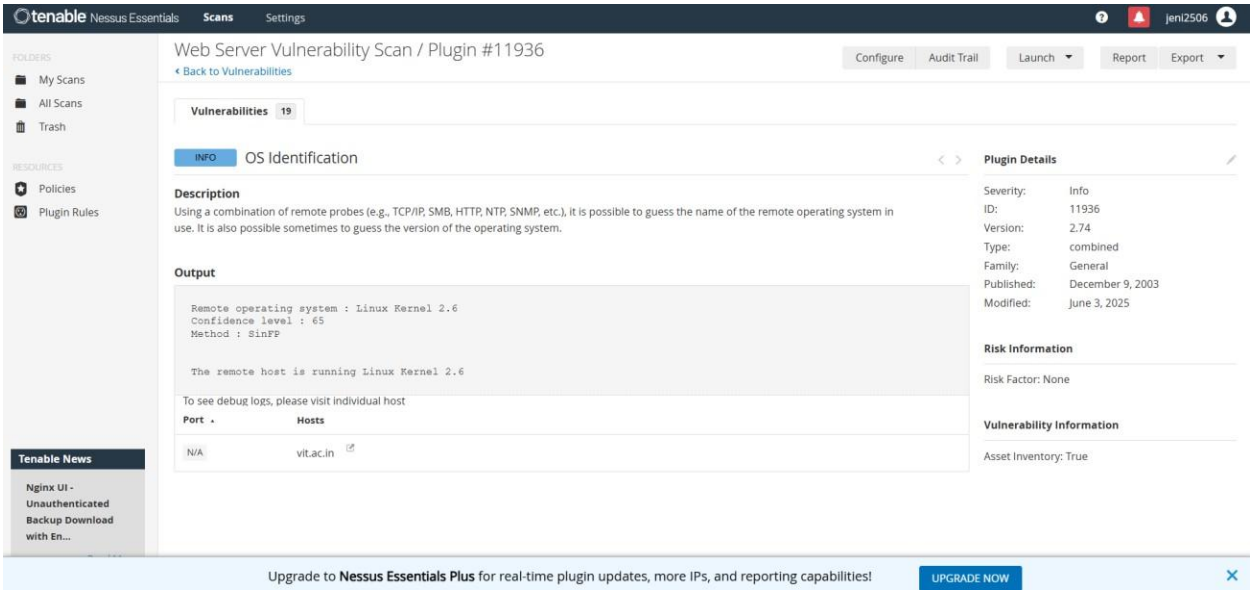
1. Open the target website.
2. Perform a vulnerability scan using Nessus scanner.
3. Analyze the scan results.
4. The scanner fails to identify the operating system of the target server.

**Recommendation :**

Ensure proper system configuration for accurate scanning.

Perform regular vulnerability assessments to detect security issues.

**Screenshot :**



# STAGE 2

## OVERVIEW:

In today's digital environment, organizations face many cybersecurity threats when users access systems from different locations and devices. Traditional security methods that only rely on usernames and passwords are no longer sufficient to protect sensitive data.

This project focuses on designing and applying context-aware access control, which is a modern security approach that evaluates multiple factors before allowing access to an application. These factors include the user's identity, the security condition of the device, the location from which the user is accessing the system, and the risk level of the application.

The system analyzes these conditions in real time and decides whether to allow access, restrict certain actions, request additional authentication such as multi-factor authentication (MFA), or block the access completely.

The goal of this project is to improve cybersecurity by implementing a Zero Trust security model, where every access request is verified before granting permission. This helps organizations protect sensitive data, prevent unauthorized access, and ensure secure usage of applications from any device or location.

In this stage, vulnerability scanning and security analysis were performed to identify potential security weaknesses in the target web application. The objective of this stage is to detect vulnerabilities that may allow attackers to gain unauthorized access or expose sensitive information.

Security testing was conducted using vulnerability assessment tools such as Nessus Scanner along with manual analysis techniques. These tools help in scanning the web server, identifying vulnerabilities, and analyzing the security posture of the application.

The scan results provide information about different types of vulnerabilities along with their severity levels. The identified issues include Cross-Site Scripting, information exposure, and configuration-related vulnerabilities.

## Tenable Nessus :

Tenable Nessus is one of the most widely used vulnerability assessment tools in cybersecurity. It is used to scan systems, networks, and web applications to identify security weaknesses that attackers might exploit.

Nessus works by using a large database of plugins, where each plugin checks for a specific vulnerability such as outdated software, misconfigured services, weak encryption protocols, and web application vulnerabilities. During a scan, Nessus analyzes the target system, identifies vulnerabilities, and classifies them based on severity levels such as Critical, High, Medium, Low, and Informational.

The tool provides detailed reports that include the vulnerability name, affected ports, plugin ID, description of the issue, and recommended solutions. Security teams use these reports to prioritize and fix vulnerabilities before attackers can exploit them.

Nessus is widely used in penetration testing, vulnerability management, and security auditing because it provides accurate scanning results and helps organizations strengthen their cybersecurity posture.

The following table shows the vulnerabilities detected during the scanning process.

| S.No | Vulnerability Name | Severity | Plugin |
|---|---|---|---|
| 1 | Cross-Site Scripting (XSS) | Medium | Multiple XSS |
| 2 | SQL Injection | High | SQL Injection Detection |
| 3 | Broken Access Control | High | Authorization Failure |
| 4 | Broken Authentication | High | Authentication Weakness |
| 5 | Insecure Direct Object Reference | Medium | Access Control Check |
| 6 | Security Misconfiguration | Medium | Configuration Audit |
| 7 | Cross-Site Request Forgery (CSRF) | Medium | CSRF Detection |
| 8 | Cleartext Transmission of Sensitive Data | Medium | SSL/TLS Weak Encryption |
| 9 | Clickjacking | Low | Frame Injection |
| 10 | Information Exposure (HTTP Header Disclosure) | Low | HTTP Information |

**VULNERABILITY REPORT:**

**1. Cross-Site Scripting (XSS)**

Plugin: Multiple XSS
Port: 80

Description:
Cross-Site Scripting (XSS) is a web vulnerability where attackers inject malicious scripts into a web application. When other users visit the affected page, the script executes in their browser.

Solution:
Validate and sanitize all user inputs and implement output encoding to prevent malicious script execution.

Business Impact:
Attackers can steal session cookies, user credentials, and perform actions on behalf of legitimate users.

**2. SQL Injection**

Plugin: SQL Injection Detection
Port: 80

Description:
SQL Injection occurs when attackers insert malicious SQL queries into input fields to manipulate the database.

Solution:
Use parameterized queries or prepared statements and validate all user inputs.

Business Impact:
Attackers may gain unauthorized access to sensitive data, modify database records, or delete critical information.

**3. Broken Access Control**

Plugin: Authorization Failure
Port: 80

Description:
Broken access control occurs when users can access resources or perform actions beyond their permitted privileges.

Solution:
Implement role-based access control and proper authorization checks.

Business Impact:
Unauthorized users may access confidential data or modify system settings.

**4. Broken Authentication**

Plugin: Authentication Weakness
Port: 80

Description:
Broken authentication vulnerabilities occur when login mechanisms are improperly implemented, allowing attackers to bypass authentication.

Solution:
Implement strong password policies and multi-factor authentication (MFA).

Business Impact:
Attackers can gain unauthorized access to user accounts and sensitive information.

**5. Insecure Direct Object Reference (IDOR)**

Plugin: Access Control Check
Port: 80

Description:
IDOR occurs when attackers manipulate object identifiers such as user IDs in URLs to access unauthorized data.

Solution:
Validate user authorization and implement proper access control mechanisms.

Business Impact:
Sensitive data belonging to other users can be accessed or modified.

**6. Security Misconfiguration**

Plugin: Configuration Audit
Port: 80

Description:
Security misconfiguration occurs when systems are improperly configured, exposing sensitive files, directories, or services.

Solution:
Apply secure configuration settings and perform regular security audits.

Business Impact:
Attackers may gain access to confidential system information or internal resources.

**7. Cross-Site Request Forgery (CSRF)**

Plugin: CSRF Detection
Port: 80

Description:
CSRF attacks trick authenticated users into performing unwanted actions on a web application.

Solution:
Implement CSRF tokens and secure session management.

Business Impact:
Attackers may perform actions such as changing account settings or transferring funds without user consent.

**8. Cleartext Transmission of Sensitive Information**

Plugin: SSL/TLS Weak Encryption
Port: 80

Description:
Sensitive data such as usernames and passwords are transmitted without encryption over the network.

Solution:
Use HTTPS and strong SSL/TLS encryption protocols.

Business Impact:
Attackers can intercept network traffic and steal sensitive information.

**9. Clickjacking**

Plugin: Frame Injection
Port: 80

Description:
Clickjacking occurs when attackers trick users into clicking hidden elements by embedding a webpage inside an invisible frame.

Solution:
Use the X-Frame-Options header and Content Security Policy.

Business Impact:
Users may unknowingly perform harmful actions on the application.

**10. Information Exposure**

Plugin: HTTP Information Disclosure
Port: 443

Description:
The web server exposes sensitive information such as server details or internal IP addresses through HTTP headers.

Solution:
Remove unnecessary server information and configure secure HTTP headers.

Business Impact:
Attackers can gather system details to plan further attacks.

# STAGE 3

## Title:Security Monitoring and Threat Detection Using SOC, SIEM, and Threat Intelligence for Network Protection

## SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization. The SOC team continuously monitors network activity, system logs, and security alerts to detect potential threats and attacks.

The main objective of SOC is to ensure the security of an organization's IT infrastructure by identifying suspicious activities and responding to them before they cause damage.

SOC teams use various security tools such as SIEM systems, intrusion detection systems, vulnerability scanners, and threat intelligence platforms to monitor and protect the network environment.

SOC plays an important role in maintaining the confidentiality, integrity, and availability of organizational data.

## SIEM Cycle

The SIEM system follows a process for analyzing and managing security data.

1. Log Collection
Logs are collected from various systems such as servers, firewalls, and applications.

2. Log Normalization
Logs are converted into a standardized format for easier analysis.

3. Event Correlation
The SIEM system analyzes logs to identify patterns and relationships between events.

4. Threat Detection
Suspicious activities are detected using predefined rules and threat intelligence.

5. Alert Generation
When a potential threat is detected, the system generates security alerts.

6. Incident Response
Security teams investigate the alert and take appropriate actions to mitigate the threat.

## MISP (Malware Information Sharing Platform)

MISP is an open-source threat intelligence platform used to share and analyze information about cybersecurity threats.

It allows organizations to exchange threat intelligence data such as:

- Malware indicators
- Attack patterns
- Indicators of Compromise (IOC)
- Threat actor information

By sharing threat intelligence, organizations can detect attacks faster and improve their security defenses.

MISP helps security teams stay updated about new cyber threats and vulnerabilities.

## College Network Information

The project can be applied to the network environment of KPR College of Arts Science and Research.

The college network consists of multiple systems and services such as:

- Student computer labs
- Faculty systems
- Administrative servers
- Wi-Fi networks
- College ERP systems
- Online learning platforms

The network is protected using security technologies such as:

- Firewalls
- Network monitoring systems
- Authentication servers
- Access control policies

Implementing SOC monitoring and SIEM solutions in the college network can help detect cyber threats and protect sensitive data such as student records and research information.

## How the Project Will Be Deployed

The deployment of this project involves several steps.

First, the network environment is scanned using vulnerability assessment tools such as Nessus to identify security weaknesses.

Next, security monitoring systems such as SIEM are implemented to collect logs from different systems within the network.

The SOC team continuously monitors these logs to detect suspicious activities and potential cyber threats.

Threat intelligence platforms such as MISP are used to gather information about new cyber threats and attack techniques.

Finally, security policies and response strategies are implemented to mitigate vulnerabilities and protect the network infrastructure.

## Threat Intelligence

Threat intelligence refers to the collection and analysis of information about cyber threats and attack methods used by hackers.

It helps organizations understand:

- How attacks are performed
- Who the attackers are
- What vulnerabilities are being targeted
- How to prevent similar attacks

Threat intelligence data is collected from sources such as:

- Security research organizations
- Threat intelligence platforms
- Cybersecurity communities
- Vulnerability databases

Using threat intelligence helps organizations improve their security strategies and respond to threats more effectively.

## RESULTS AND SECURITY RECOMMENDATIONS

After completing the vulnerability scanning and analysis process, several security issues were identified in the target web application. The vulnerability assessment was performed using tools such as Nessus Scanner, Burp Suite, and manual testing techniques. The scan results revealed different types of vulnerabilities including Cross-Site Scripting (XSS), outdated JavaScript libraries, information exposure through HTTP headers, and configuration-related issues.

The vulnerability scan categorized the issues into different severity levels such as Medium, Low, and Informational. Medium-level vulnerabilities like DOM-Based Cross-Site Scripting and outdated jQuery versions can allow attackers to execute malicious scripts in the user's browser. These vulnerabilities can potentially lead to session hijacking, data theft, or unauthorized access.

Low-level vulnerabilities such as HTTP header internal IP disclosure may expose sensitive server details. Attackers can use this information to better understand the system architecture and plan further attacks on the web server.

Informational vulnerabilities including SSL certificate details, HTTP information disclosure, and OS identification failures provide additional information about the server environment. While these vulnerabilities may not directly lead to attacks, they can assist attackers in gathering intelligence about the system.

To improve the overall security of the application, several security recommendations are suggested. Web developers should implement proper input validation and output encoding to prevent injection attacks such as Cross-Site Scripting. Outdated libraries such as older versions of jQuery should be updated to the latest secure versions to eliminate known vulnerabilities.

Additionally, server configuration should be improved by hiding sensitive HTTP headers and internal IP addresses. Secure communication protocols such as HTTPS with strong SSL/TLS encryption should be used to protect data transmitted over the network. Regular security testing and vulnerability scanning should also be performed to identify new threats and ensure continuous protection of the system.

By implementing these security practices, organizations can significantly reduce the risk of cyberattacks and maintain a secure environment for users and applications.

**TOOLS USED**

The project involved the use of several cybersecurity tools and technologies to perform vulnerability scanning and security analysis. These tools help security professionals identify weaknesses in web applications and understand potential attack vectors.

**Kali Linux :** Kali Linux is a penetration testing operating system that contains a large collection of cybersecurity tools used for ethical hacking, vulnerability analysis, and network security testing. It provides an environment for performing security assessments on systems and web applications.

**Nessus Vulnerability Scanner :** Nessus is a widely used vulnerability scanning tool that detects security flaws, misconfigurations, and outdated software components in servers and web applications. It provides detailed reports that include vulnerability descriptions, severity levels, and remediation recommendations.

**Burp Suite :** Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests and responses between the browser and the web server. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting, and authentication issues.

**Web Browser :** A web browser such as Google Chrome or Mozilla Firefox is used to access the target web application and perform manual security testing. Browser developer tools help inspect web page elements and analyze scripts.

**Uniscan Tool :** Uniscan is a web vulnerability scanning tool used to detect hidden directories, configuration issues, and potential vulnerabilities in web applications.

These tools collectively help security analysts perform effective vulnerability assessments and improve the overall security posture of web applications.

**CONCLUSION**

The main objective of this project was to design and apply context-aware access control concepts while performing vulnerability assessment on web applications. With the rapid growth of digital technologies and online services, cybersecurity has become an essential requirement for protecting sensitive data and system resources.

Through this project, various web application vulnerabilities were identified and analyzed using security testing tools. The vulnerability scanning process helped in understanding how attackers exploit weaknesses in web applications and how these vulnerabilities can impact the security of an organization.

The analysis revealed several vulnerabilities including Cross-Site Scripting, outdated software components, information exposure issues, and configuration weaknesses. Each vulnerability highlights the importance of implementing secure coding practices, proper system configuration, and regular security testing.

This project demonstrates the role of vulnerability assessment and security testing in improving application security. By identifying and addressing security weaknesses, organizations can prevent potential cyberattacks, protect user data, and maintain system integrity.

Overall, the project emphasizes the importance of proactive security measures, continuous monitoring, and regular vulnerability scanning to ensure a secure digital environment. Implementing strong security policies and modern access control mechanisms will help organizations protect their systems against evolving cyber threats.

# Future Scope

The future scope of this project includes the integration of advanced cybersecurity technologies such as:

- Artificial Intelligence for threat detection
- Automated incident response systems
- Cloud security monitoring
- Advanced threat intelligence platforms
- Machine learning-based anomaly detection

These technologies can further enhance the ability of organizations to detect and prevent cyber attacks.

## Tools Used

- Tenable Nessus
- Burp Suite
- Kali Linux
- Web Browsers
- Vulnerability Databases (OWASP, CWE)

## Tools Explored

- MISP (Malware Information Sharing Platform)
- SIEM platforms such as Splunk and ELK Stack
- Network monitoring tools
- Penetration testing tools